

BÀI 3

Dò tìm lỗ hổng bảo mật thông tin A. Thăm dò

Nội dung

Thăm dò (FootPrinting)

- Khái niệm chung
- Đối tượng thăm dò
- Các mối đe dọa
- Một số kỹ thuật thăm dò
 - WHOIS Footprinting
 - DNS Footprinting
 - Network Footprinting
 - Website Footprinting
 - E-mail Footprinting
 - Google Hacking
- Biện pháp phòng chống
- Bài tập

Khái niệm chung

- Báo chí, phim ảnh... thường xuyên đưa lên những câu chuyện về xâm nhập hệ thống máy tính.
- Tin tặc là những thiên tài?
- Thực tế phức tạp hơn và việc tấn công vào một hệ thống đòi hỏi mất nhiều thời gian nghiên cứu mục tiêu.
- Tin tặc có thể sử dụng những công cụ do người khác viết và tải xuống từ Internet để tấn công mục tiêu.

Khái niệm chung



Đối tượng thăm dò



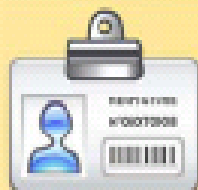
Collect Network Information

- Domain name
- Internal domain names
- Network blocks
- IP addresses of the reachable systems
- Rogue websites/private websites
- TCP and UDP services running
- Networking protocols
- VPN Points
- ACLs
- IDSes running
- Analog/digital telephone numbers
- Authentication mechanisms



Collect System Information

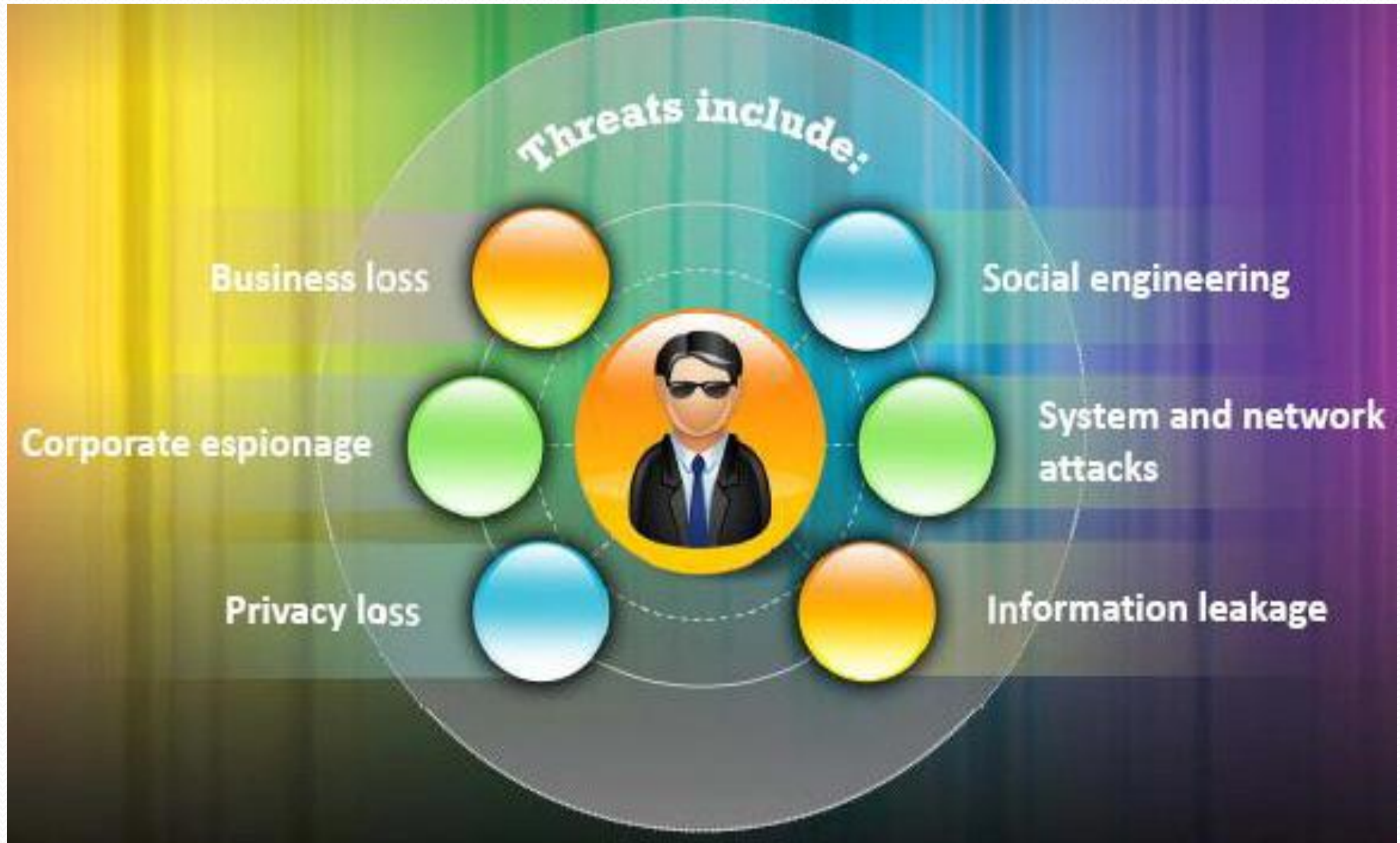
- User and group names
- System banners
- Routing tables
- SNMP information
- System architecture
- Remote system type
- System names
- Passwords



Collect Organization's Information

- Employee details
- Organization's website
- Company directory
- Address and phone numbers
- Background on the organization
- News articles/press releases

Các mối đe dọa



Một số kỹ thuật thăm dò

Footprinting Methodology



Internet
Footprinting



Competitive
Intelligence



WHOIS
Footprinting



DNS
Footprinting



Network
Footprinting



Website
Footprinting



E-mail
Footprinting



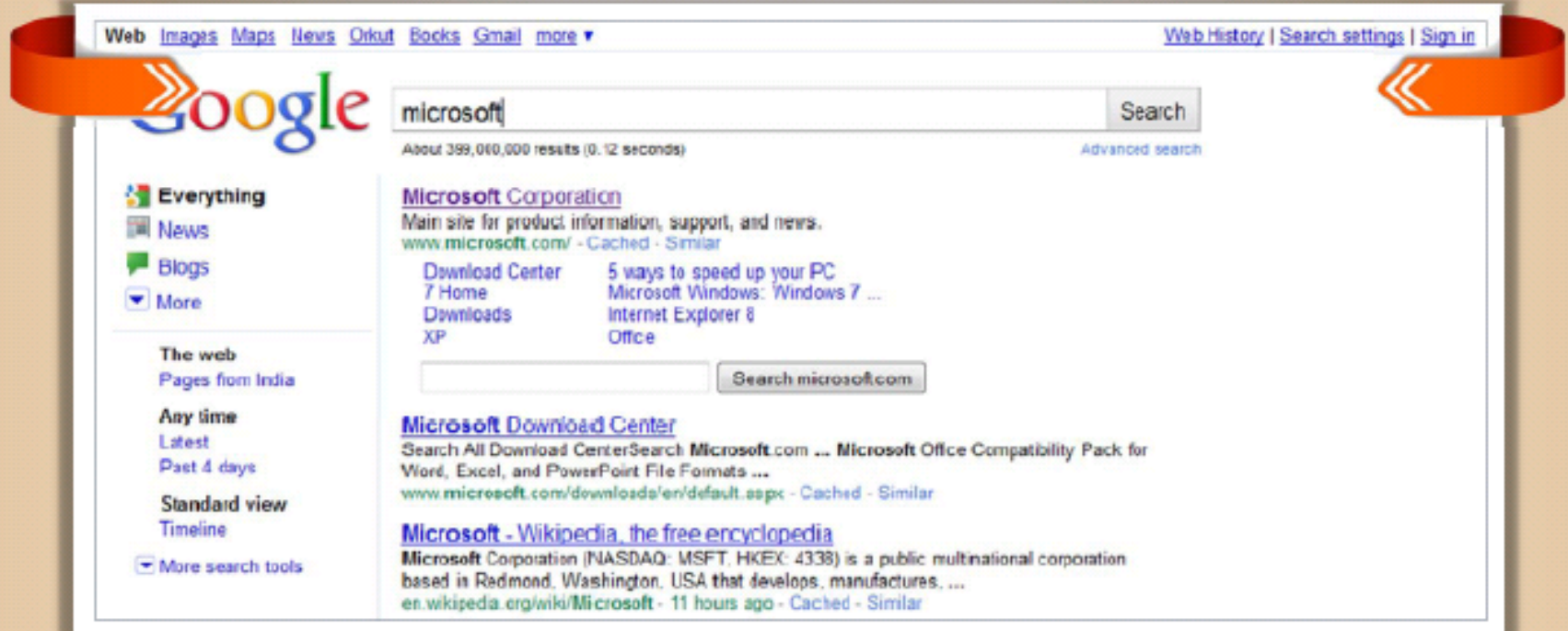
Google
Hacking



Một số kỹ thuật thăm dò

Finding a Company's URL

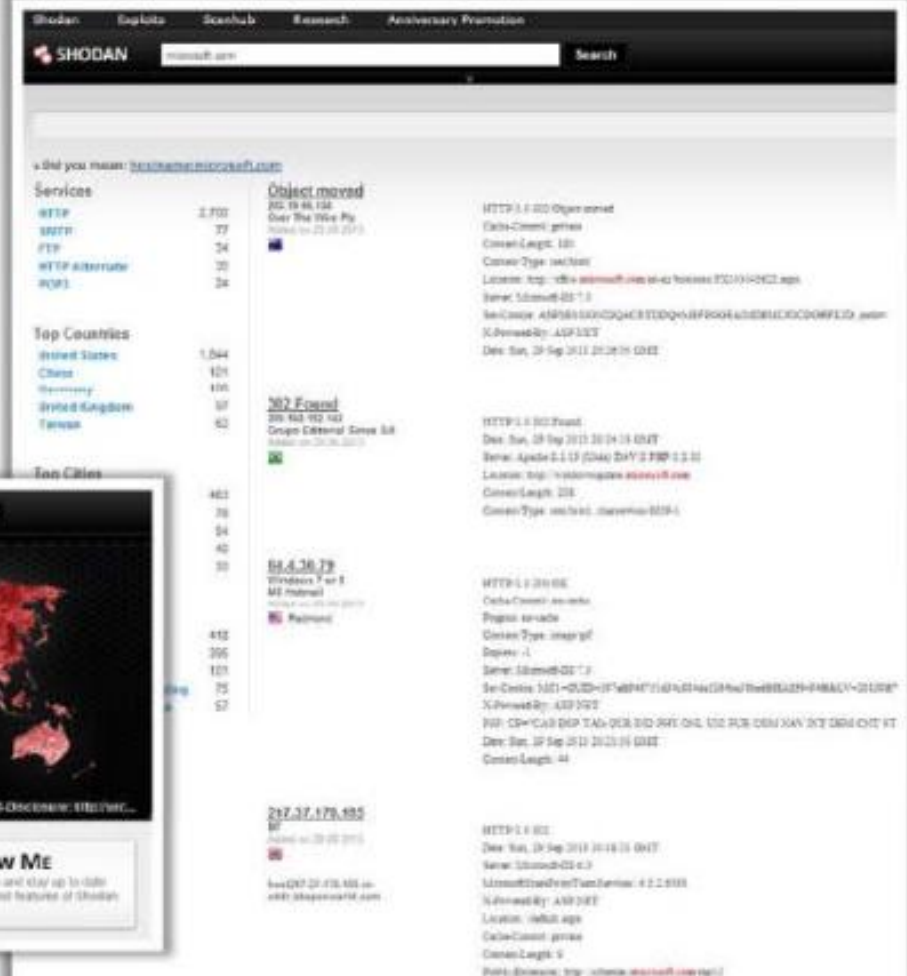
- Search for the target company in a search engine such as **Google** or **Bing**



Một số kỹ thuật thăm dò

Determining the Operating System

Use SHODAN search engine that lets you **find specific computers** (routers, servers, etc.) using a variety of filters



<http://www.shodanhq.com>

Một số kỹ thuật thăm dò

Search for Company's Information



Một số kỹ thuật thăm dò

Tools to Extract **Company's Data**

I

Web Data Extractor (<http://www.webextractor.com>)

- Web Data Extractor **extracts the targeted company's contact data** (email, phone, fax) from the Internet

II

SpiderFoot (<http://www.binarypool.com>)

- SpiderFoot is a domain footprinting tool which will **scrape the websites** on that domain, as well as search Google, Netcraft, Whois, and DNS to collect the company information

III

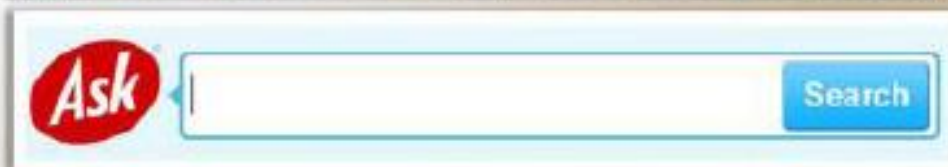
Robtex (<http://www.robtex.com>)

- Robtex utilites **crawl the Internet** using the useragent "robtexbot," mainly to get title and meta information

Một số kỹ thuật thăm dò

Footprinting Through Search Engines

- Attackers use search engines to **extract information about a target** such as technology platforms, employee details, login pages, intranet portals, etc. which helps in performing social engineering and other types of advanced system attacks
- Search engine **cache may provide sensitive information** that has been removed from the World Wide Web (WWW)



Một số kỹ thuật thăm dò

Collect Location Information

Google Earth

Use **Google Earth** tool to get the physical location of the target



<http://www.google.com>

Tools for finding the geographical location

Google Maps

<https://maps.google.com>

Wikimapia

<http://www.wikimapia.org>

National Geographic Maps

<http://maps.nationalgeographic.com>

Yahoo Maps

<http://maps.yahoo.com>

Bing Maps

<http://www.bing.com/maps>

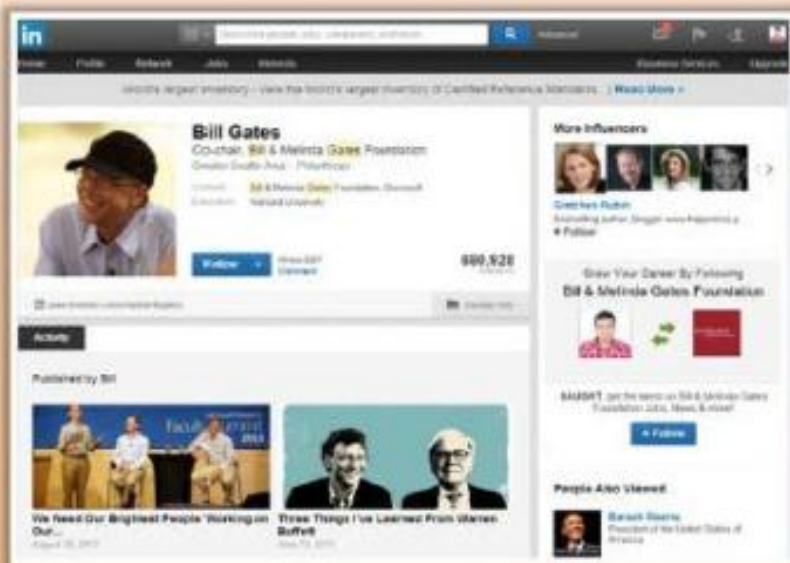
Một số kỹ thuật thăm dò

People Search: Social Networking Sites/People Search Services

- Social networking sites are the great source of personal and organizational information
- Information about an individual can be found at various **people search websites**
- The people search returns the following **information about a person or organization**:



- Residential addresses and email addresses
- Contact numbers and date of birth
- Photos and social networking profiles
- Blog URLs
- Satellite pictures of private residences
- Upcoming projects and operating environment



Một số kỹ thuật thăm dò

Information Available on Social Networking Sites



Một số kỹ thuật thăm dò

Gather Information from Financial Services

Financial services provide a useful information about the target company such as the **market value of a company's shares, company profile, competitor details**, etc.



Một số kỹ thuật thăm dò

Information Gathering Using Groups, Forums, and Blogs



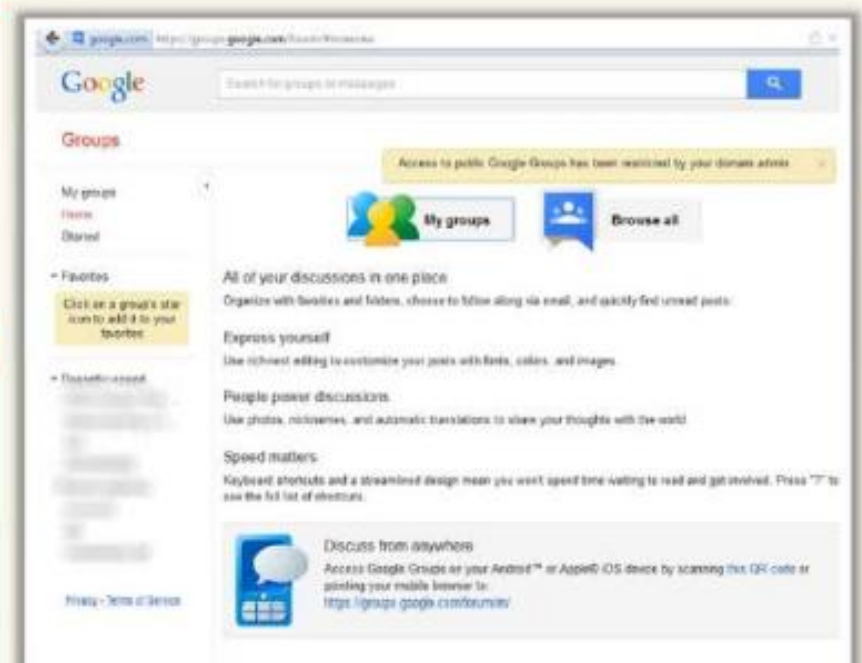
Groups, forums, and blogs provide sensitive information about a target such as **public network information, system information, personal information**, etc.



Register with fake profiles in **Google groups, Yahoo groups**, etc. and try to join the target organization's employee groups where they share personal and company information



Search for information by Fully Qualified Domain Names (**FQDNs**), **IP addresses**, and **usernames** in groups, forums, and blogs



Một số kỹ thuật thăm dò

People Search on Social Networking Services



The image shows the Orkut login page. On the left, the Orkut logo is displayed with the tagline "Connect with friends and family using email and instant messaging. Discover new people through friends of friends and communities. Share your ideas, pictures, and videos all in one place." Below this, it says "orkut makes it so much easier to stay in touch with all your friends while on the go, both here and abroad." At the bottom of the left section are links for "Google", "Search", "Help", "Privacy", "Terms", and "About". On the right, there is a login form with fields for "Email" and "Password". Above the "Password" field is a checkbox for "Remember me on this computer". Below the "Password" field is a "Sign in" button. To the right of the "Sign in" button is a link for "Forgot your password?". Below the login form is a link for "Not a member yet? Sign up".

<http://www.orkut.com>



The image shows the Facebook login page. At the top, the Facebook logo is displayed. Below the logo, there is a navigation bar with links for "Home", "Search", "Groups", "Marketplace", and "More". The main content area is divided into two sections. On the left, there is a large image of a globe with people icons connected by lines, representing a social network. On the right, there is a "Sign Up" section with the text "It's free and anyone can join". Below this, there are input fields for "First Name", "Last Name", "Your Email", and "Your Password". There is also a "Select Sex" dropdown menu and a "Month" dropdown menu. Below these fields is a "Sign Up" button. At the bottom of the page, there is a footer with links for "About", "Privacy", "Terms", "Help", "Feedback", and "Advertise".

<http://www.facebook.com>



The image shows the LinkedIn login page. At the top, the LinkedIn logo is displayed. Below the logo, there is a navigation bar with links for "Home", "Search", "Groups", "Marketplace", and "More". The main content area is divided into two sections. On the left, there is a large image of a globe with people icons connected by lines, representing a social network. On the right, there is a "Sign Up" section with the text "It's free and anyone can join". Below this, there are input fields for "First Name", "Last Name", "Your Email", and "Your Password". There is also a "Select Sex" dropdown menu and a "Month" dropdown menu. Below these fields is a "Sign Up" button. At the bottom of the page, there is a footer with links for "About", "Privacy", "Terms", "Help", "Feedback", and "Advertise".

<http://www.linkedin.com>



The image shows the Twitter login page. At the top, the Twitter logo is displayed. Below the logo, there is a navigation bar with links for "Home", "Search", "Groups", "Marketplace", and "More". The main content area is divided into two sections. On the left, there is a large image of a globe with people icons connected by lines, representing a social network. On the right, there is a "Sign Up" section with the text "It's free and anyone can join". Below this, there are input fields for "First Name", "Last Name", "Your Email", and "Your Password". There is also a "Select Sex" dropdown menu and a "Month" dropdown menu. Below these fields is a "Sign Up" button. At the bottom of the page, there is a footer with links for "About", "Privacy", "Terms", "Help", "Feedback", and "Advertise".

<http://twitter.com>

WHOIS Footprinting

WHOIS Lookup

WHOIS databases are maintained by Regional Internet Registries and contain the **personal information of domain owners**

WHOIS Query Returns

1. Domain name details
2. Contact details of domain owner
3. Domain name servers
4. NetRange



Regional Internet Registry

1. AfriNIC
2. ARIN
3. APNIC
4. LACNIC, RIPE NCC

WHOIS Lookup Tools

- <http://www.tamos.com>
- <http://netcraft.com>
- <http://www.whois.net>
- <http://www.iptools.com>



Attackers Look for

1. Physical location
2. Telephone number
3. Email address
4. Technical and administrative contacts



WHOIS Footprinting

WHOIS Lookup Tools: SmartWhois

- SmartWhois is a useful network information utility that allows you to look up all the available information about an **IP address**, **hostname**, or **domain**
- It also provides information about **country**, **state or province**, **city**, name of the network provider, administrator, and technical support contact information



WHOIS Footprinting

WHOIS Lookup Tools for Mobile

DNS Tools



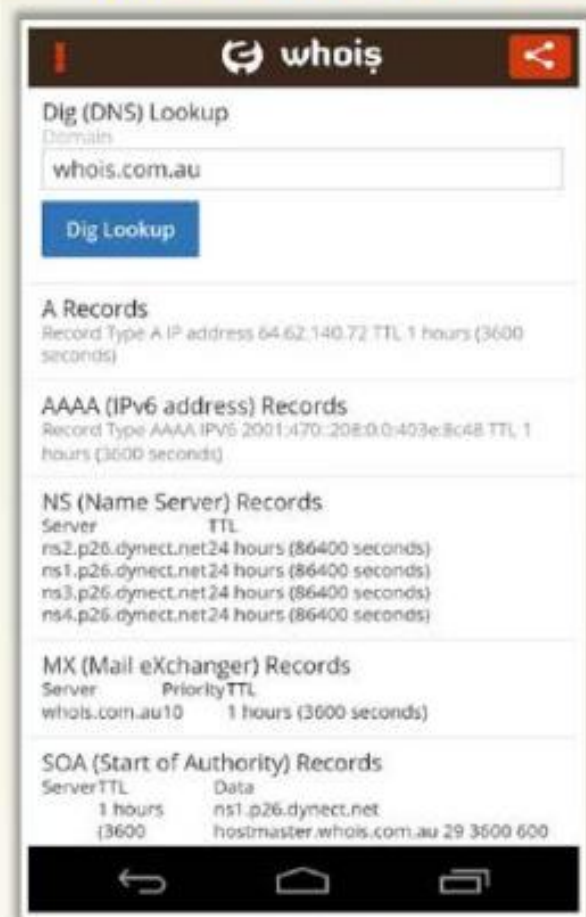
<https://www.dnssniffer.com>

UltraTools Mobile



<https://www.ultratools.com>

Whois® Lookup Tool



<http://www.whois.com.au>

WHOIS Footprinting

WHOIS Lookup Tools



Sam Spade

<http://samspade.org>



My IP Suite

<http://www.sabsoft.com>



CountryWhois

<http://www.tamos.com>



LanWhois

<http://lantricks.com>



NetRanger Whois

<http://www.conceira.com>



Lapshins Whois

<http://lapshins.com>



Alchemy Eye

<http://www.alchemy-lab.com>



WebFerret

<http://www.webferret.com>

WHOIS Footprinting

WHOIS Lookup Online Tools



Whois

<http://tools.whois.net>



Whois Lookup

<http://www.ip-tools.com>



Better Whois

<http://www.betterwhois.com>



Geek Whois

<http://www.geektools.com>



Arin Whois Database Search

<http://whois.arin.net>



Network Solutions Whois

<http://www.networksolutions.com>



DomainTools

<http://www.domaintools.com>



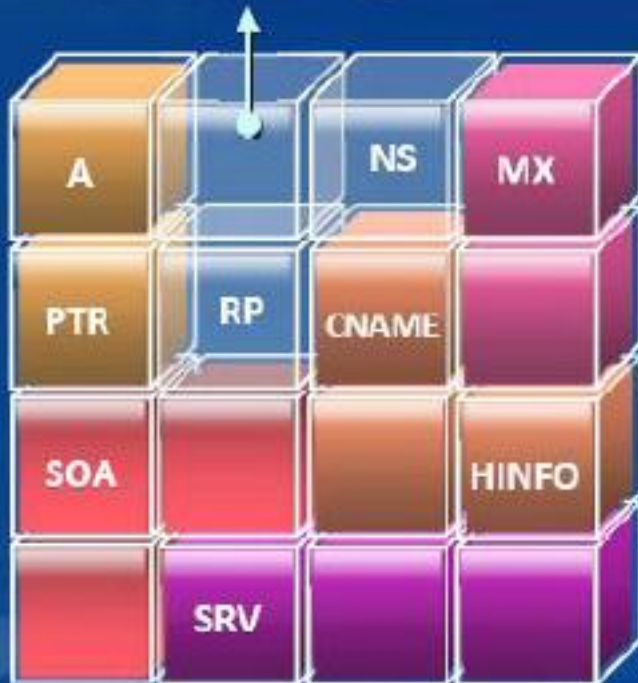
AutoWhois

<http://centralops.net>

DNS Footprinting

Extracting DNS Information

DNS Record Type



DNS Records provide important information about location and type of servers

- A** - Points to a host's IP address
- MX** - Points to domain's mail server
- NS** - Points to host's name server
- CNAME** - Canonical naming allows aliases to a host
- SOA** - Indicate authority for domain
- SRV** - Service records
- PTR** - Maps IP address to a hostname
- RP** - Responsible person
- HINFO** - Host information record includes CPU type and OS

DNS Interrogation Tools

- <http://www.dnsstuff.com>
- <http://www.checkdns.net>

- <http://network-tools.com>
- <http://www.iptools.com>

DNS Footprinting

Domain Dossier

DNS records

name	class	type	data	time to live
yahoo.com	IN	SOA	server: ns1.yahoo.com email: hostmaster@yahoo-inc.com serial: 2015040304 refresh: 3600 retry: 300 expire: 1814400 minimum ttl: 600	1800s (00:30:00)
yahoo.com	IN	A	98.138.253.109	1800s (00:30:00)
yahoo.com	IN	A	206.190.36.45	1800s (00:30:00)
yahoo.com	IN	A	98.139.183.24	1800s (00:30:00)
yahoo.com	IN	MX	preference: 1 exchange: mta5.am0.yahoodns.net	1800s (00:30:00)
yahoo.com	IN	MX	preference: 1 exchange: mta5.am0.yahoodns.net	1800s (00:30:00)
yahoo.com	IN	MX	preference: 1 exchange: mta7.am0.yahoodns.net	1800s (00:30:00)
yahoo.com	IN	NS	ns4.yahoo.com	172800s (2:00:00:00)
yahoo.com	IN	NS	ns6.yahoo.com	172800s (2:00:00:00)
yahoo.com	IN	NS	ns5.yahoo.com	172800s (2:00:00:00)
yahoo.com	IN	NS	ns3.yahoo.com	172800s (2:00:00:00)
yahoo.com	IN	NS	ns2.yahoo.com	172800s (2:00:00:00)
yahoo.com	IN	NS	ns1.yahoo.com	172800s (2:00:00:00)
yahoo.com	IN	TXT	v=spf1 redirect=_spf.mail.yahoo.com	1800s (00:30:00)
109.253.138.99.in-addr.arpa	IN	PTR	k1.fq.slp.net1.yahoo.com	1800s (00:30:00)
253.138.98.in-addr.arpa	IN	NS	ns4.yahoo.com	172800s (2:00:00:00)
253.138.98.in-addr.arpa	IN	NS	ns1.yahoo.com	172800s (2:00:00:00)
253.138.98.in-addr.arpa	IN	NS	ns3.yahoo.com	172800s (2:00:00:00)
253.138.98.in-addr.arpa	IN	NS	ns5.yahoo.com	172800s (2:00:00:00)
253.138.98.in-addr.arpa	IN	NS	ns2.yahoo.com	172800s (2:00:00:00)
253.138.98.in-addr.arpa	IN	TXT	Contact for this domain is Yahoo! NOC, +1 408 348 5555	1800s (00:30:00)
253.138.98.in-addr.arpa	IN	SOA	server: niden-master.yahoo.com email: hostmaster@yahoo-inc.com serial: 2014101602 refresh: 3600 retry: 600 expire: 5184000 minimum ttl: 1800	600s (00:10:00)

<http://centralops.net>

DNS Lookup

DNS Lookup for microsoft.com

Searching for microsoft.com ANY Record at c.root-servers.net [192.33.4.12] referred to f.gld-servers.net
Searching for microsoft.com ANY Record at f.gld-servers.net [192.35.51.30] referred to ns1.msft.net
Searching for microsoft.com ANY Record at ns1.msft.net [208.84.0.53]

Results from ns1.msft.net [IP: 208.84.0.53] for microsoft.com ANY Record

Domain	Type	Time to Live	Answer
Answer			
microsoft.com	A	3600 [1 Hour]	134.170.188.221
microsoft.com	A	3600 [1 Hour]	134.170.185.46
microsoft.com	NS	172800 [2 Days]	ns4.msft.net
microsoft.com	NS	172800 [2 Days]	ns1.msft.net
microsoft.com	NS	172800 [2 Days]	ns2.msft.net
microsoft.com	NS	172800 [2 Days]	ns3.msft.net
microsoft.com	SOA	3600 [1 Hour]	Primary Name Server: ns1.msft.net Responsible: ns1.msft.net/microsoft.com Serial Number: 2015040301 Refresh: 7200 [2 Hours] Retry: 600 [10 Minutes] Expire: 2419200 [28 Days] Minimum Time to Live: 3600 [1 Hour]
microsoft.com	MX	3600 [1 Hour]	microsoft.com.mail.protection.outlook.com [Preference: 10]
microsoft.com	TXT	3600 [1 Hour]	FbUF6D6kE+Aw1w@xgDl8KwllZus5v8L6tbIQZkGrQhYVQKJ

<https://network-tools.webwiz.co.uk>

DNS Footprinting

DNS Interrogation Tools



NetInspector

<http://www.globware.com>



NSLOOKUP

<http://www.kloth.net>



DigDug, DNS Analyzer

<http://www.edge-security.com>



MSR Strider URL Tracer

<http://research.microsoft.com>



WhereISIP

<http://www.wherisip.com>



Dnsmap

<http://www.linuxhaxor.net>



Multiple Addresses

<http://www.checkdns.net>



DNS Tool

<http://www.hendricom.com>

DNS Footprinting

DNS Interrogation Online Tools



Online DNS Tools

<http://www.ajaxdns.com>



Better Whois

<http://www.betterwhois.com>



Professional Toolset

<http://www.dnsstuff.com>



Geek Whois

<http://www.geektools.com>



DNS Record

<http://network-tools.com>



Mozzle Domain Name Pro

<http://www.mozzle.com>



Check DNS

<http://www.checkdns.net>



Domain Information Groper

<http://www.kloth.net>

Network Footprinting

Locate the Network Range

TARGET

010001011010111001010

1. Find the range of IP addresses
2. Use ARIN whois database search tool

You can find the range of **IP addresses** and the **subnet mask** used by the target organization from Regional Internet Registry (RIR)

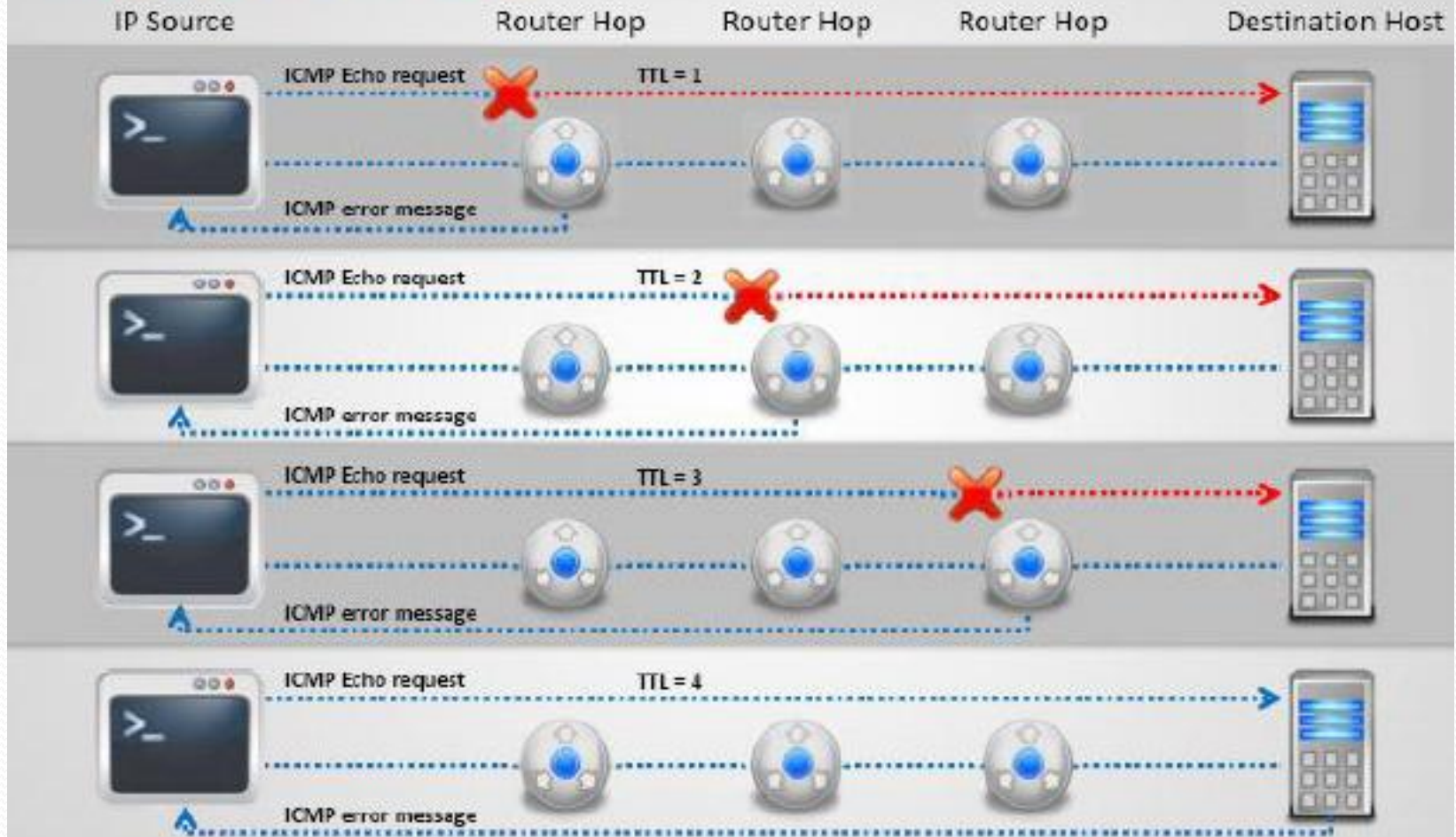
Network Whois record

Queried whois.arin.net with "n 207.46.232.102"...

NetRange: 207.46.0.0 - 207.46.255.255
CIDR: 207.46.0.0/16
OriginAS:
NetName: MICROSOFT-GLOBAL-NET
NetHandle: NET-207-46-0-0-1
Parent: NET-207-0-0-0-0
NetType: Direct Assignment
NameServer: NS2.MSFT.NET
NameServer: NS4.MSFT.NET
NameServer: NS1.MSFT.NET
NameServer: NS5.MSFT.NET
NameServer: NS3.MSFT.NET
RegDate: 1997-03-31
Updated: 2004-12-09
Ref: <http://whois.arin.net/rest/net/NET-207-46-0-0-1>
OrgName: Microsoft Corp
OrgId: MSFT
Address: One Microsoft Way
City: Redmond
StateProv: WA
PostalCode: 98052
Country: US
RegDate: 1998-07-10
Updated: 2009-11-10
Ref: <http://whois.arin.net/rest/org/MSFT>
OrgAbuseHandle: ABUSE231-ARIN
OrgAbuseName: Abuse
OrgAbusePhone: +1-425-882-8080
OrgAbuseEmail: abuse@hotmail.com
OrgAbuseRef: <http://whois.arin.net/rest/poc/ABUSE231-ARIN>

Network Footprinting

Traceroute



Traceroute programs work on the concept of **ICMP protocol** and use the **TTL field in the header of ICMP packets** to discover the routers on the path to a target host

Network Footprinting

Traceroute Analysis

I

Attackers conduct traceroute to extract information about: network topology, trusted routers, and firewall locations

II

For example: after running several traceroutes, an attacker might obtain the following information:

- traceroute 1.10.10.20, second to last hop is 1.10.10.1
- traceroute 1.10.20.10, third to last hop is 1.10.10.1z
- traceroute 1.10.20.10, second to last hop is 1.10.10.50
- traceroute 1.10.20.15, third to last hop is 1.10.10.1
- traceroute 1.10.20.15, second to last hop is 1.10.10.50

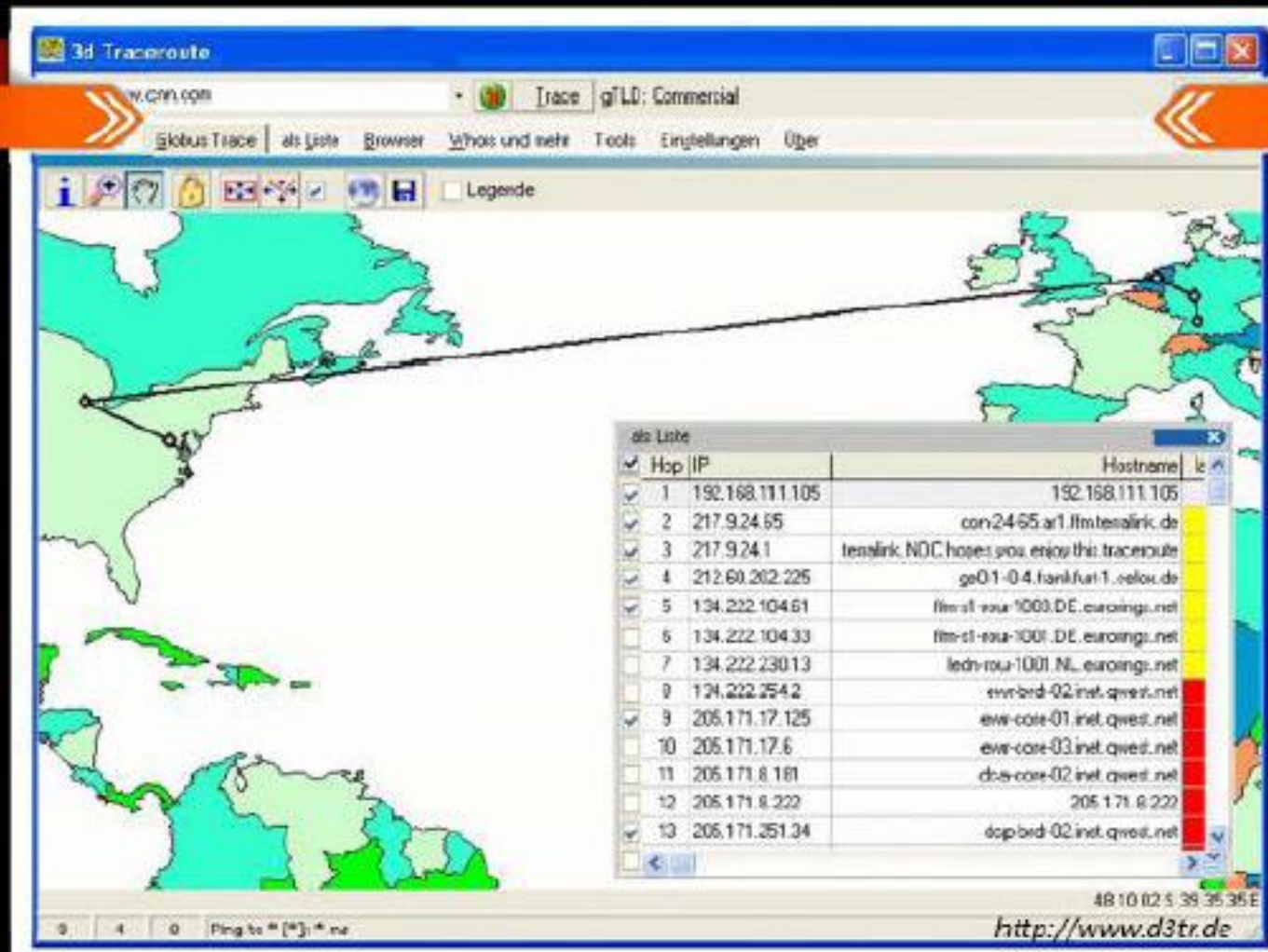
III

By putting this information together, attackers can draw the network diagram



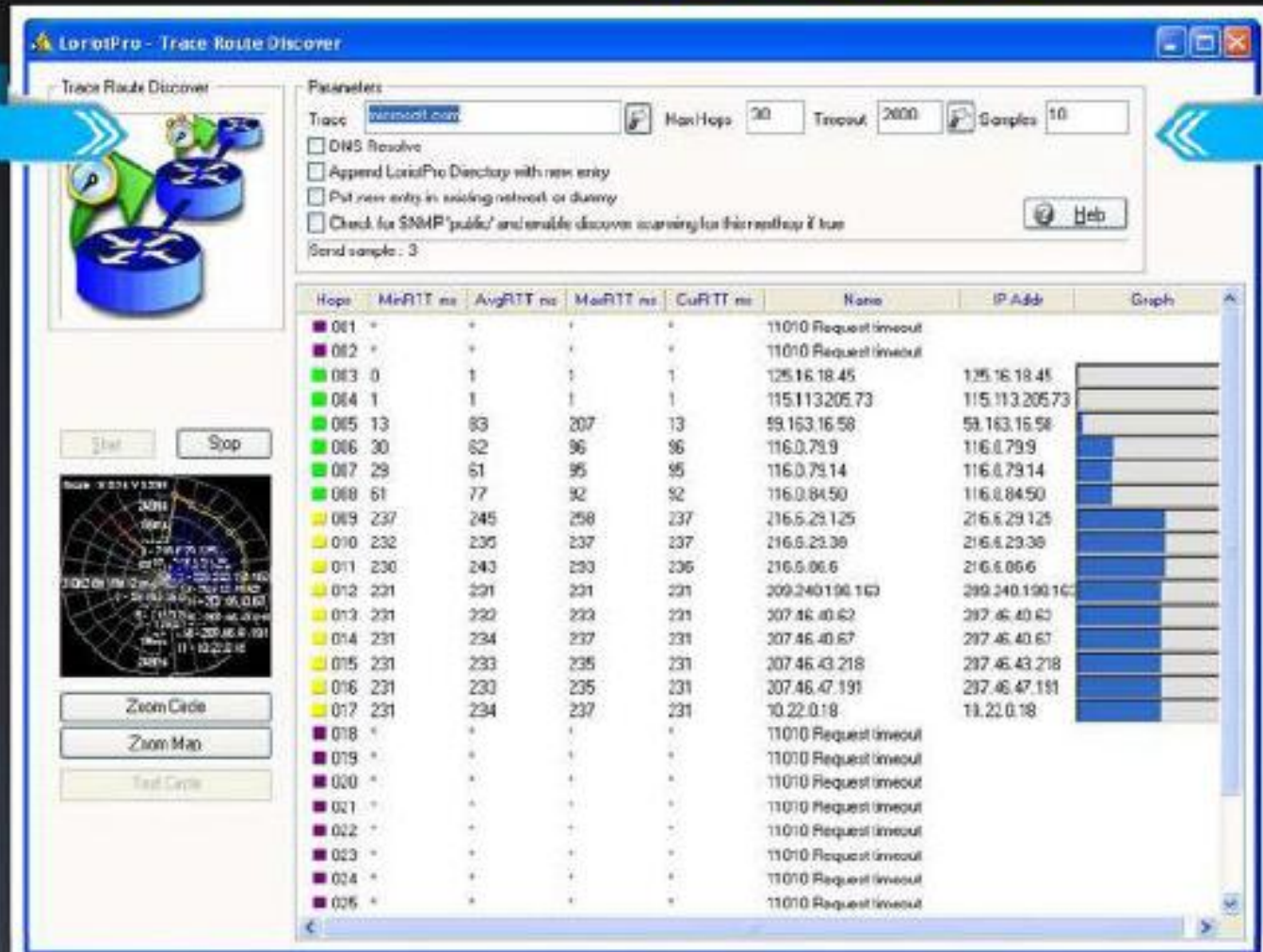
Network Footprinting

Traceroute Tool: 3D Traceroute



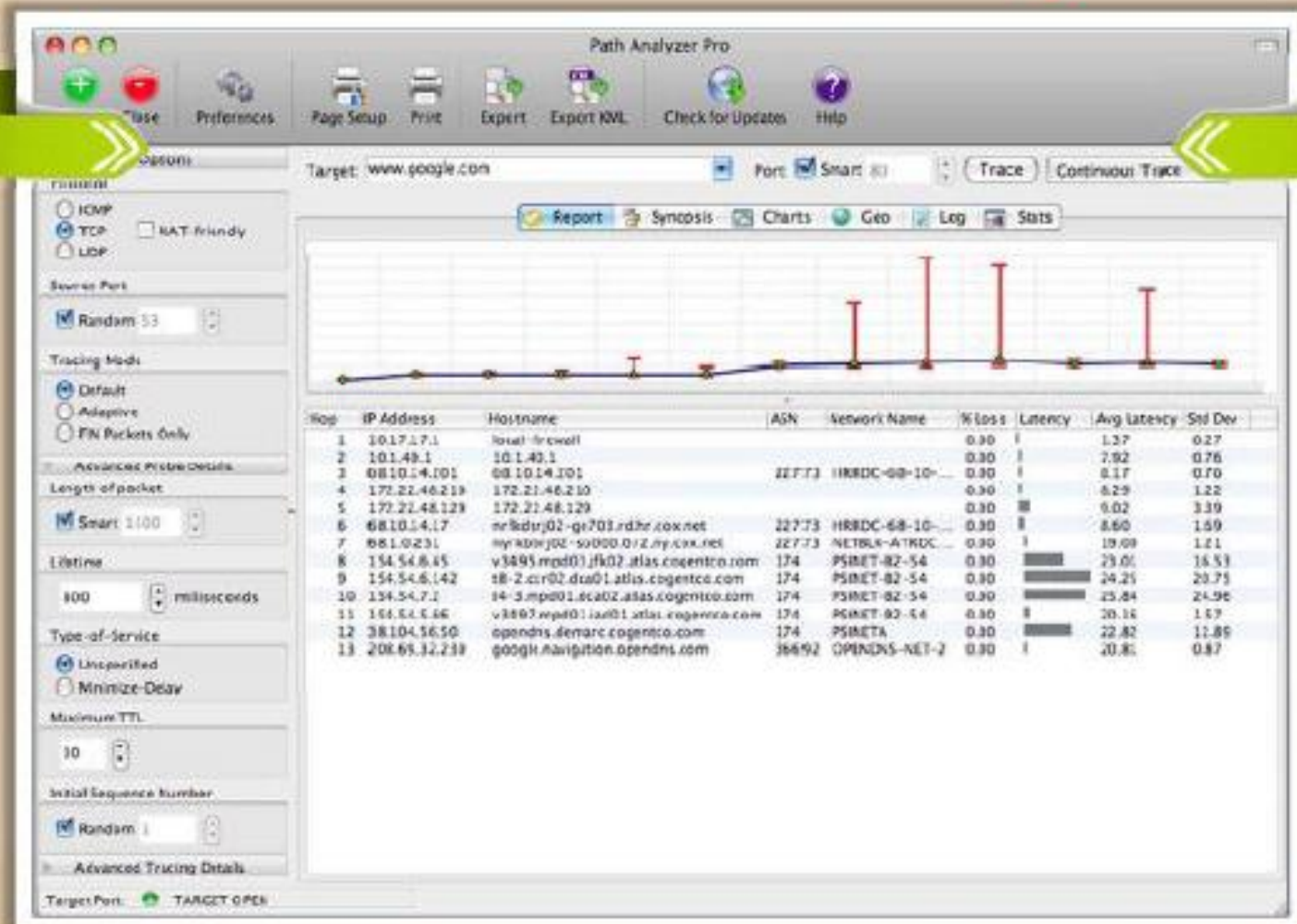
Network Footprinting

Traceroute Tool: **LoriotPro**



Network Footprinting

Traceroute Tool: Path Analyzer Pro



Network Footprinting

Traceroute Tools



VisualRoute Trace

<http://visualroute.visualware.com>



vTrace

<http://vitrace.pl>



3d Visual Trace Route

<http://www.3dsnmp.com>



Trout

<http://www.foundstone.com>



GEOSpider

<http://www.oreware.com>



Magic NetTrace

<http://www.tialsoft.com>



Visual IP Trace

<http://www.visualiptrace.com>



Patrice Zwenger Traceroute

<http://patrice-zwenger.co.cc>

Website Footprinting



1

Website footprinting refers to **monitoring and analyzing the target organization's website** for information

2

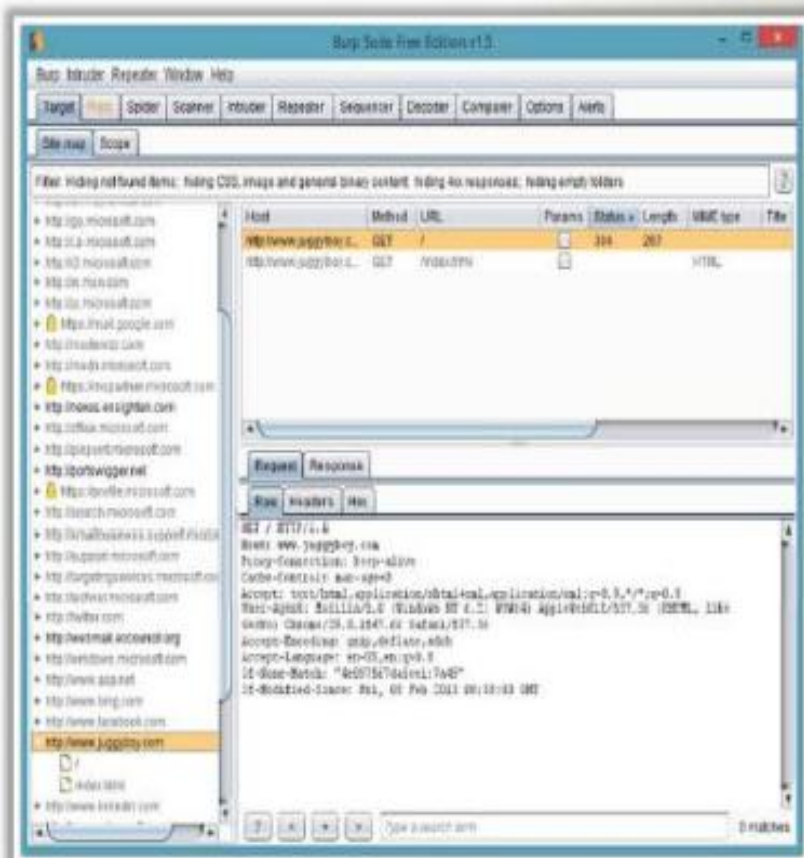
Browsing the target website may provide:

- Software used and its version
- Operating system used
- Sub-directories and parameters
- Filename, path, database field name, or query
- Scripting platform
- Contact details and CMS details

3

Use **Burp Suite, Zaproxy, Paros Proxy, Website Informer, Firebug**, etc. to view headers that provide:

- Connection status and content-type
- Accept-Ranges
- Last-Modified information
- X-Powered-By information
- Web server in use and its version



Website Footprinting

Mirroring Entire Website

Web mirroring tools allows you to **download a website to a local directory**, building recursively all directories, HTML, images, flash, videos and other files from the server to your computer

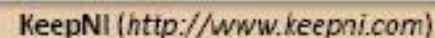
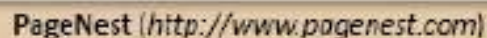
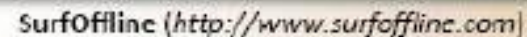
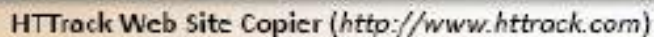


Original Website



Mirrored Website

Website Mirroring Tools



Website Footprinting

Mirroring Entire Website Tools



Wget

<http://www.gnu.org>



Website Ripper Copier

<http://www.tensons.com>



Webripper

<http://calluna-software.com>



WinWSD

<http://winwsd.uw.hu>



BlackWidow

<http://softbytelabs.com>



Reamweaver

<http://reamweaver.com>



xaldon webspider 2

<http://www.xaldon.de>



Teleport Pro

<http://www.tenmax.com>

Website Footprinting using Web Spiders

- ## GSA Email Spider



Website Footprinting

Extract Website Information from

<http://www.archive.org>



Internet Archive **Wayback Machine** allows you to visit archived versions of Web sites

Enter Web Address:

All ▾

Take Me Back

[Adv. Search](#) [Compare Archive Pages](#)

Searched for <http://www.microsoft.com>

Archived Results from Jan 01, 1996 - latest

2001	2002	2003	2004	2005	2006	2007	2008	2009	2010
263 pages	130 pages	30 pages	160 pages	175 pages	278 pages	200 pages	133 pages	7 pages	1 pages
Jan 03, 2001	Jan 21, 2002	Jan 30, 2003	Jan 10, 2004	Jan 04, 2005	Jan 01, 2006	Jan 02, 2007	Jan 01, 2008	Jul 23, 2009	Feb 23, 2010
Jan 03, 2001	Jan 25, 2002	Feb 08, 2003	Jan 17, 2004	Jan 10, 2005	Jan 01, 2006	Jan 03, 2007	Jan 02, 2008	Jul 23, 2009	
Jan 04, 2001	Jan 27, 2002	Feb 20, 2003	Jan 24, 2004	Jan 14, 2005	Jan 01, 2006	Jan 07, 2007	Jan 03, 2008	Oct 18, 2009	
Jan 05, 2001	Jan 03, 2002	Mar 21, 2003	Feb 02, 2004	Jan 15, 2005	Jan 01, 2006	Jan 07, 2007	Jan 04, 2008	Oct 18, 2009	
Jan 06, 2001	Jun 04, 2002	Mar 24, 2003	Feb 07, 2004	Jan 16, 2005	Jan 01, 2006	Jan 08, 2007	Jan 04, 2008	Oct 26, 2009	
Jan 06, 2001	Jun 05, 2002	Mar 28, 2003	Feb 08, 2004	Jan 17, 2005	Jan 01, 2006	Jan 09, 2007	Jan 05, 2008	Oct 27, 2009	
Jan 07, 2001	Jul 01, 2002	Apr 11, 2003	Feb 09, 2004	Jan 18, 2005	Jan 02, 2006	Jan 12, 2007	Jan 06, 2008	Oct 27, 2009	
Jan 08, 2001	Jul 02, 2002	May 06, 2003	Feb 14, 2004	Jan 19, 2005	Jan 02, 2006	Jan 14, 2007	Jan 08, 2008		
Jan 08, 2001	Jul 03, 2002	May 13, 2003	Feb 21, 2004	Jan 20, 2005	Jan 02, 2006	Jan 17, 2007	Jan 09, 2008		
Jan 08, 2001	Jul 03, 2002	May 29, 2003	Feb 28, 2004	Jan 21, 2005	Jan 02, 2006	Jan 25, 2007	Jan 09, 2008		
Jan 08, 2001	Jul 04, 2002	Jun 18, 2003	Mar 06, 2004	Jan 22, 2005	Jan 02, 2006	Jan 25, 2007	Jan 10, 2008		
Jan 18, 2001	Jul 07, 2002	Jun 18, 2003	Mar 13, 2004	Jan 23, 2005	Jan 03, 2006	Jan 28, 2007	Jan 10, 2008		
Jan 18, 2001	Jul 08, 2002	Jun 23, 2003	Mar 25, 2004	Jan 24, 2005	Jan 03, 2006	Jan 29, 2007	Jan 11, 2008		
Jan 30, 2001	Jul 09, 2002	Jun 24, 2003	Apr 01, 2004	Jan 25, 2005	Jan 03, 2006	Jan 30, 2007	Jan 12, 2008		
Feb 02, 2001	Jul 11, 2002	Jul 17, 2003	Apr 10, 2004	Jan 26, 2005	Jan 04, 2006	Feb 01, 2007	Jan 17, 2008		
Feb 02, 2001	Jul 12, 2002	Aug 05, 2003	Apr 15, 2004	Jan 27, 2005	Jan 04, 2006	Feb 02, 2007	Jan 18, 2008		
Feb 24, 2001	Jul 13, 2002	Aug 07, 2003	Apr 18, 2004	Jan 28, 2005	Jan 04, 2006	Feb 02, 2007	Jan 19, 2008		
Feb 28, 2001	Jul 14, 2002	Sep 25, 2003	May 18, 2004	Jan 29, 2005	Jan 05, 2006	Feb 03, 2007	Jan 19, 2008		
Mar 01, 2001	Jul 15, 2002	Oct 01, 2003	May 22, 2004	Jan 30, 2005	Jan 05, 2006	Feb 04, 2007	Jan 21, 2008		

Website Footprinting

INTERNET ARCHIVE
wayBackMachine

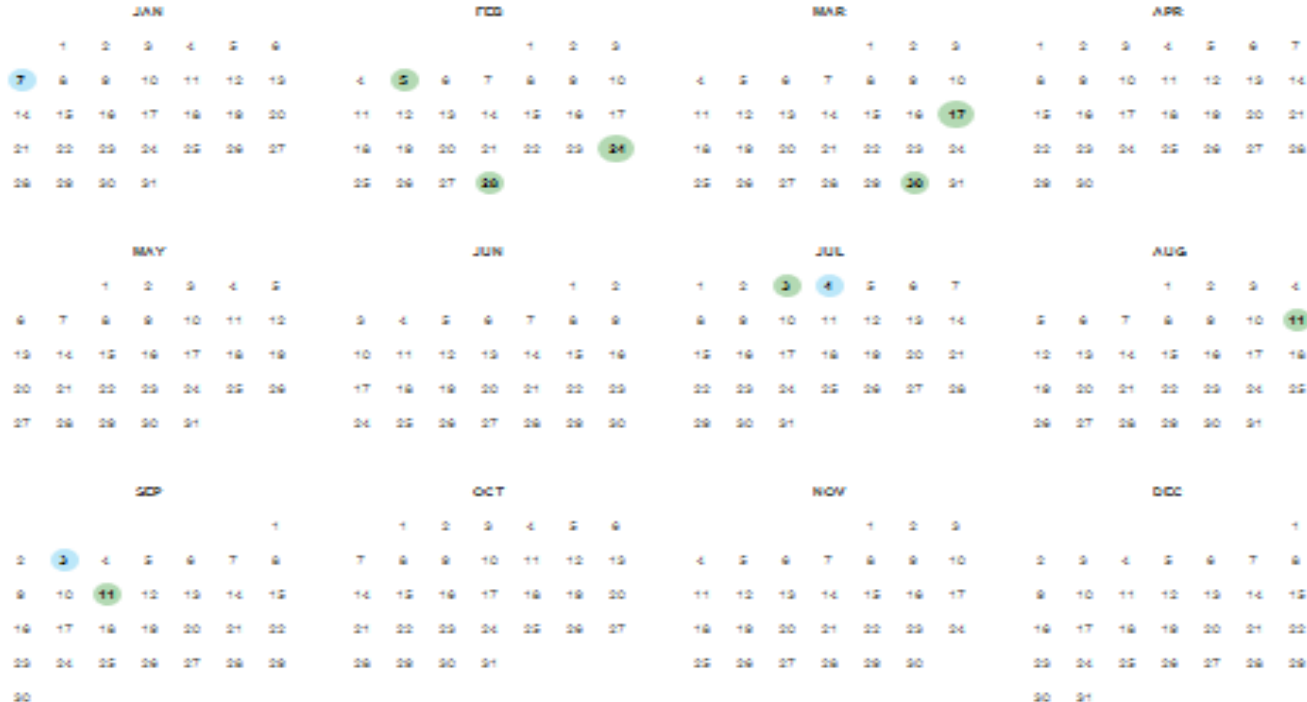
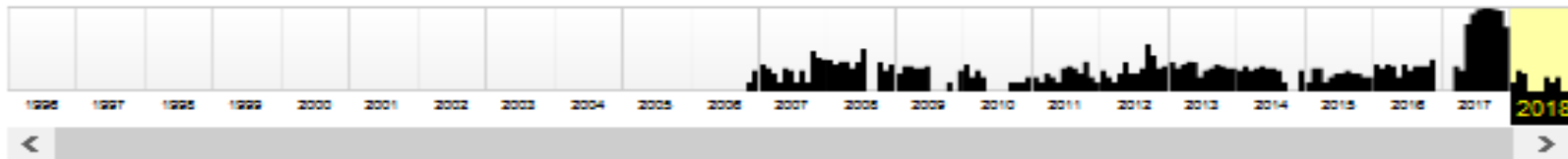
Explore more than 338 billion web pages saved over time

OK

DONATE

Saved 4,804 times between November 10, 2006 and September 11, 2018.

[Summary of uit.edu.vn](#) - [Site Map of uit.edu.vn](#)



Website Footprinting

Monitoring Web Updates Using Website Watcher

The screenshot displays the Website-Watcher 2010 application window. The left sidebar shows a file explorer with folders like 'General', 'Magazines', 'News', 'private', 'Programming', 'Tools', and 'wswatch'. The main window features a table of monitored websites with columns for Name, URL, Last change, Status, and Last check. Below the table is a 'Download' section for Website-Watcher 2010 (10.0), showing a download button (3.8 MB) and a mirror button (3.8 MB). A yellow callout box points to the download section with the text: 'Web page with highlighted changes (yellow) and highlighted keywords (blue)'. The bottom status bar shows 'Bookmarks: 95 [4]' and the URL 'http://aignes.com'.

Name	URL	Last change	Status	Last check
DIR wswatch	D:\wswatch	2010-04-01 12:5805	OK	2010-04-01 ..
news//asp.members.te...	news//asp.me...	2010-04-01 09:51:17	OK	2010-04-01 ..
Website-Watcher + Dow...	http://www.w...	2010-04-01 12:43:54	OK	2010-04-01 ..
Website-Watcher + Sup...	http://www.w...	2010-04-01 12:46:46	OK, phpBB2 PL...	2010-04-01 ..
WSW Forum RSS	http://www.w...	2010-04-01 11:03:53	OK	2010-04-01 ..
www.website-watcher.c...	http://www.w...	2010-04-01 11:52:48	OK	2010-04-01 ..
www.website-watcher.e...	http://aignes.e...	2008-07-08 19:12:59	OK	2008-07-08 ..

Website-Watcher 2010 (10.0) - 02-Feb-2010

Download (3.8 MB) Mirror (3.8 MB)

System: 2008, XP, Vista, 7, Ser... 2003/2008
[Version History](#)

If you install a new version...
version over the old one!

Download our other products

Local Website Archive 3.1.1
Archive web pages for future reference
3 MB Download Mirror More Info...

Page / Text / Analyse

Bookmarks: 95 [4] <http://aignes.com>

Email Footprinting

Collecting Information from Email Header

Delivered-To: [redacted]@gmail.com
Received: by 10.112.39.167 with SMTP id q7cs
Sat, 1 Jun 2013 21:24:01 -0700 (PDT)
Return-Path: <[redacted]@gmail.com>
Received-SPF: pass (google.com: domain of [redacted] designates 10.224.205.137 as permitted sender) client-ip=10.224.205.137;
Authentication-Results: mr.google.com: spf=pass (domain of [redacted]@gmail.com designates 10.224.205.137 as permitted sender) smtp.mail=[redacted]@gmail.com; dkim=pass header.i=[redacted]@gmail.com
Received: from mr.google.com ([10.224.205.137])
by 10.224.205.137 with SMTP id fq9mr8578570qab.39.1
Sat, 01 Jun 2013 21:24:00 -0700 (PDT)
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
d=gmail.com; s=20120113;
h=mime-version:in-reply-to:reference:content-type;
bh=TGEIPb4ti7gfQG+ghh7OkPjkx+Tt/iAC1
b=KguZLTlfq2+QZXzZKexlNnvRcnD/+P4+Nk5NKSPtG7uHXDsFv/hGH46e2P+75MxDR8
blPK3eJ3Uf/CsaBZWDIT0XLAK0AGrP3Bot92MCZFxeUUQ9uWl/xHALSnkeUIEEeKGqOC
oa9hD59D3oXI8KAC7ZmkblGzXmV4D1WffCL894RaMBOUomzRwOWWIib95a1I38cqt1fP
ZhrWFKh5xSn2XsE73xZPEYzp7yecCeQuYH2NGs1KxcO7xQjeZuw+HWK/vR6xChDjap24
K5ZAFYZmkIKFX+VdLZqu7YGFzy6oHcuPl6yS/C2fXHVdsuYamMT/yecvhCvo8Og7FKt6
/Kzw==
MIME-Version: 1.0
Received: by 10.224.205.137 with SMTP id fq9mr8578570qab.39.1040318;
Sat, 01 Jun 2013 21:24:00 -0700 (PDT)
Received: by 10.229.230.79 with HTTP; Sat, 1 Jun 2013 21:24:00 (PDT)
In-Reply-To: <CAOYWATT1zdDXE3o8D2rhiE4Ber2ev@mail.gmail.com>
References: <CAOYWATT1zdDXE3o8D2rhiE4Ber2MtV0uhro6r+7Mu7c8ubp8Eq@mail.gmail.com>
Date: Sun, 2 Jun 2013 09:53:59 +0530
Message-ID: <CAMSvoXT0qEjnfW8WJdSzQhNnO=EMJcgfgX+mUfjB_tt2sy2dXA@mail.gmail.com>
Subject: ... SOLUTIONS :::
From: [redacted] Mirza <[redacted]@gmail.com>
To: [redacted]@gmail.com,
[redacted] SOLUTIONS <[redacted]@gmail.com>, [redacted]_er@yahoo.com>

The address from which the message was sent

Sender's IP address

Sender's mail server

Date and time received by the originator's email servers

Authentication system used by sender's mail server

Date and time of message sent

A unique number assigned by mr.google.com to identify the message

Sender's full name

Email Footprinting

Tracking Email Communications

E-mail tracking is a method to **monitor and spy** the delivered e-mails to the intended recipient

01	When the email was received and read
02	Send destructive emails
03	GPS location and map of the recipient
04	Time spent on reading the emails
05	Whether or not the recipient visited any links sent to them
06	Track PDF and other types of attachments
07	Set messages to expire after a specified time



Email Footprinting

Email Tracking Tools

eMailTrackerPro
<http://www.emailtrackerpro.com>



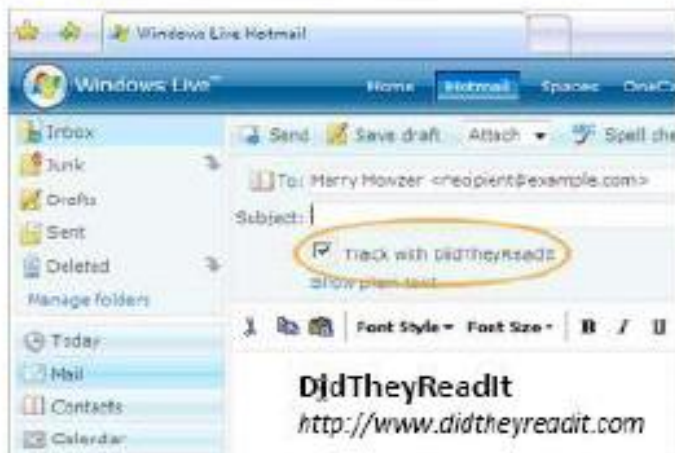
Read Notify
<http://www.readnotify.com>



PoliteMail
<http://www.politemail.com>



DidTheyReadIt
<http://www.didtheyreadit.com>



Email Footprinting

Email Tracking Tools



VisualRoute Trace

<http://visualroute.visualware.com>



GEOSpider

<http://www.oreware.com>



vTrace

<http://vtrace.pl>



Magic NetTrace

<http://www.tialsoft.com>



3d Visual Trace Route

<http://www.3dsnmp.com>



Visual IP Trace

<http://www.visualiptrace.com>



Trout

<http://www.foundstone.com>



Patrice Zwenger Traceroute

<http://patrice-zwenger.co.cc>

Google Hacking

Footprint Using Google Hacking Techniques

Query String

Google hacking is a term that refers to the art of creating complex **search engine queries**

Vulnerable Sites

It detects websites that are **vulnerable** to numerous exploits and vulnerabilities

Google Operators

It uses Google operators to **locate specific strings of text** within the search results

Google Hacking

What a Hacker Can Do With Google Hacking?



Google Hacking

Google **Advance Search** Operators

Google supports several advanced operators that help in **modifying** the search

<code>[cache:]</code>	Shows the version of the web page that Google has in its cache
<code>[link:]</code>	Lists web pages that have links to the specified web page
<code>[related:]</code>	Lists web pages that are "similar" to a specified web page.
<code>[info:]</code>	Will present some information that Google has about that web page
<code>[site:]</code>	If you include <code>[site:]</code> in your query, Google restricts the results to those websites in the given domain
<code>[allintitle:]</code>	If you start a query with <code>[allintitle:]</code> , Google restricts the results to those with all of the query words in the title
<code>[intitle:]</code>	If you include <code>[intitle:]</code> in your query, Google restricts the results to documents containing that word in the title
<code>[allinurl:]</code>	If you start a query with <code>[allinurl:]</code> , Google restricts the results to those with all of the query words in the url
<code>[inurl:]</code>	If you include <code>[inurl:]</code> in your query, Google restricts the results to documents containing that word in the url

Google Hacking

Google Hacking Tools



MetaGoofil

<http://www.edge-security.com>



Google Cartography

<http://richard.jones.name>



Goolink Scanner

<http://www.ghacks.net>



Google Hack Honeypot

<http://ghh.sourceforge.net>



SiteDigger

<http://www.foundstone.com>



GMapCatcher

<http://code.google.com>



Google Hacks

<http://code.google.com>



BiLE Suite

<http://www.sensepost.com>

Google Hacking

Additional Footprinting Tools



Prefix Whois

<http://pwwhois.org>



NetScanTools Pro

<http://www.netscantools.com>



**DMitry (Deepmagic
Information Gathering Tool)**

<http://www.mor-poh.net>



Netmask

<http://www.phenoelit-us.org>



Tctrace

<http://www.phenoelit-us.org>



Maltego

<http://www.paterva.com>



**Autonomous System
Scanner (ASS)**

<http://www.phenoelit-us.org>



Host

<http://linux.die.net>

Biện pháp phòng chống



Restrict the **employees** to access social networking sites from organization's network



Configure **web servers** to avoid information leakage



Educate employees to **use pseudonyms** on blogs, groups, and forums



Do not reveal critical information in **press releases, annual reports, product catalogues**, etc.



Limit the **amount of information** that you are publishing on the website/ Internet



Use **footprinting techniques** to discover and remove any sensitive information publicly available



Prevent search engines from caching a web page and **use anonymous registration services**

Biện pháp phòng chống



Enforce security policies to regulate the information that employees can reveal to third parties



Set apart internal and external DNS or use split DNS, and **restrict zone transfer** to authorized servers



Disable directory listings in the web servers



Educate employees about various **social engineering tricks and risks**



Opt for privacy services on **Whois Lookup database**



Avoid domain-level cross-linking for the critical assets



Encrypt and **password protect** sensitive information

Biện pháp phòng chống

Footprinting Pen Testing

- Footprinting pen test is used to determine **organization's publicly available information on the Internet** such as network architecture, operating systems, applications and users
- The tester attempts to gather as much information as possible about the target organization from **internet and other publicly accessible sources**



Prevent **DNS record retrieval** from publically available servers



Footprinting Pen testing helps administrator to:



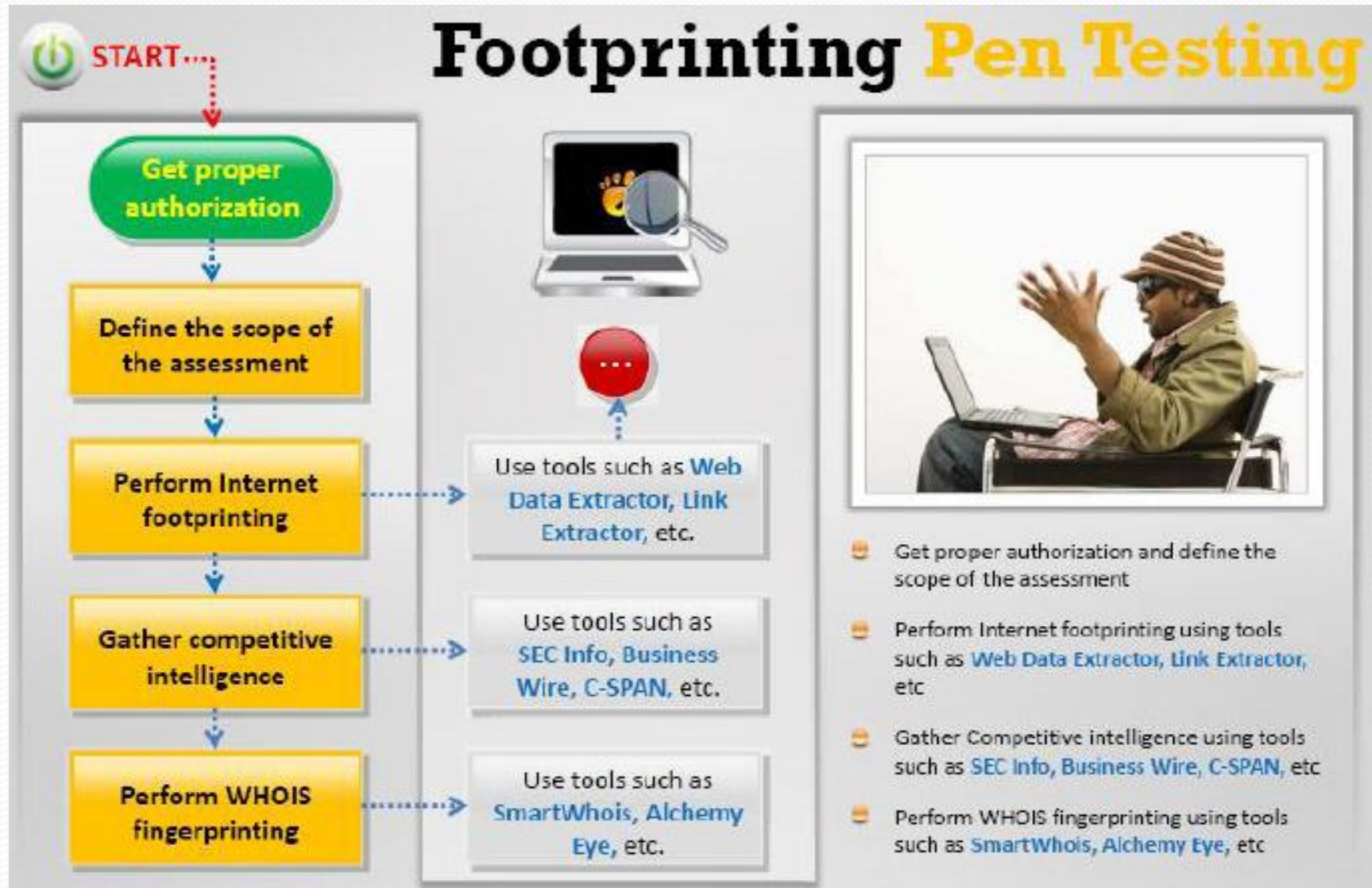
Prevent **information leakage**



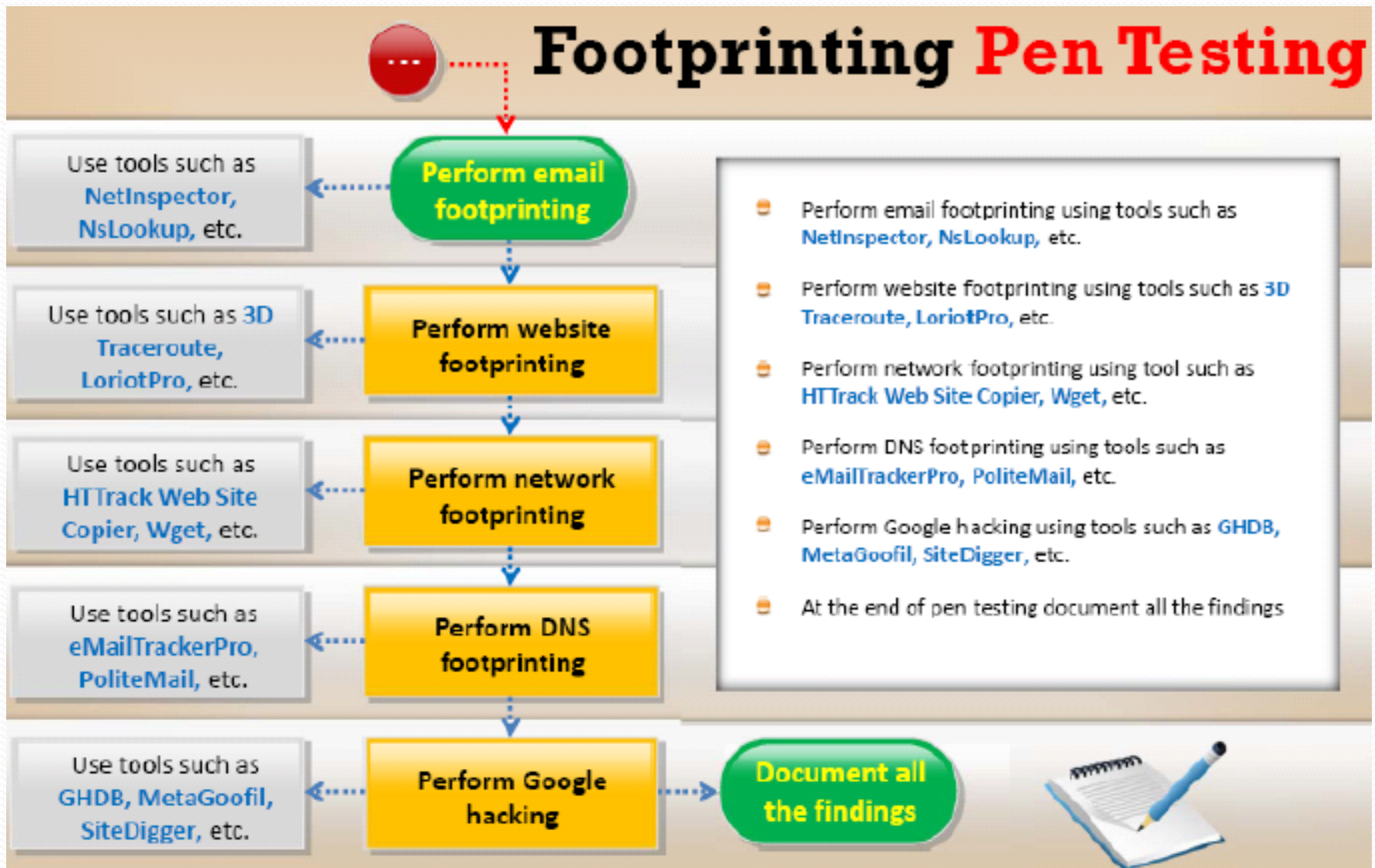
Prevent **social engineering attempts**



Biện pháp phòng chống



Biện pháp phòng chống



Biện pháp phòng chống

Footprinting Pen Testing Report Templates

Pen Testing Report	
Information obtained through search engines	Information obtained through social networking sites
 Employee details:	 Personal profiles:
 Login pages:	 Work related information:
 Intranet portals:	 News and potential partners of the target company:
 Technology platforms:	 Educational and employment backgrounds:
 Others:	 Others:
Information obtained through people search	Information obtained through website footprinting
 Date of birth:	 Operating environment:
 Contact details:	 Filesystem structure:
 Email ID:	 Scripting platforms used:
 Photos:	 Contact details:
 Others:	 CMS details:
Information obtained through Google	 Others:
 Advisories and server vulnerabilities:	Information obtained through email footprinting
 Error messages that contain sensitive information:	 IP address:
 Files containing passwords:	 GPS location:
 Pages containing network or vulnerability data:	 Authentication system used by mail server:
 Others:	 Others:

Biện pháp phòng chống

Footprinting Pen Testing Report Templates

Pen Testing Report	
Information obtained through competitive intelligence	Information obtained through network footprinting
 Financial details:	 Range of IP addresses:
 Project plans:	 Subnet mask used by the target organization:
 Others:	 OS's in use:
	 Firewall locations:
Information obtained through WHOIS footprinting	 Others:
 Domain name details:	
 Contact details of domain owner:	
 Domain name servers:	
 Netrange:	
 When a domain has been created:	
 Others:	
	Information obtained through social engineering
Information obtained through DNS footprinting	 Personal information:
 Location of DNS servers:	 Financial information:
 Type of servers:	 Operating environment:
 Others:	 User names and passwords:
	 Network layout information:
	 IP addresses and names of servers:
	 Others:

BÀI TẬP

1. Lập bảng trình bày các kỹ thuật thăm dò (phương pháp, công cụ, mục tiêu...).
2. Nêu các biện pháp phòng chống thăm dò (7-8 biện pháp), liệt kê theo thứ tự ưu tiên (quan trọng) từ cao đến thấp.

Tên file: Bài tập 3A_họ tên_mssv.doc